

ENTERPRISE SECURITY ASSESSMENT LAB

API Security Evidence Documentation Report

Excessive Data Exposure Review Evidence

Professional Portfolio Edition - Authorized API Security Lab Evidence

Field	Details
Test Area	Excessive data exposure
Result Type	Data exposure review
Evidence Report File	09-excessive-data-exposure-hidden-fields-evidence-report.pdf
Testing Phase	API Response Content Review
Tool / Component	Postman Response Viewer
OWASP / Security Mapping	API3:2023 Broken Object Property Level Authorization
Repository Path	02-api-security/reports/evidence/
Prepared For	GitHub recruiter portfolio documentation

This report documents one API Security evidence row as a standalone professional artifact. It includes the embedded screenshot, what it proves, the methodology context, command/workflow, sanitized output style, risk interpretation, remediation guidance, and publication redaction requirements.

1. Embedded Evidence Screenshot

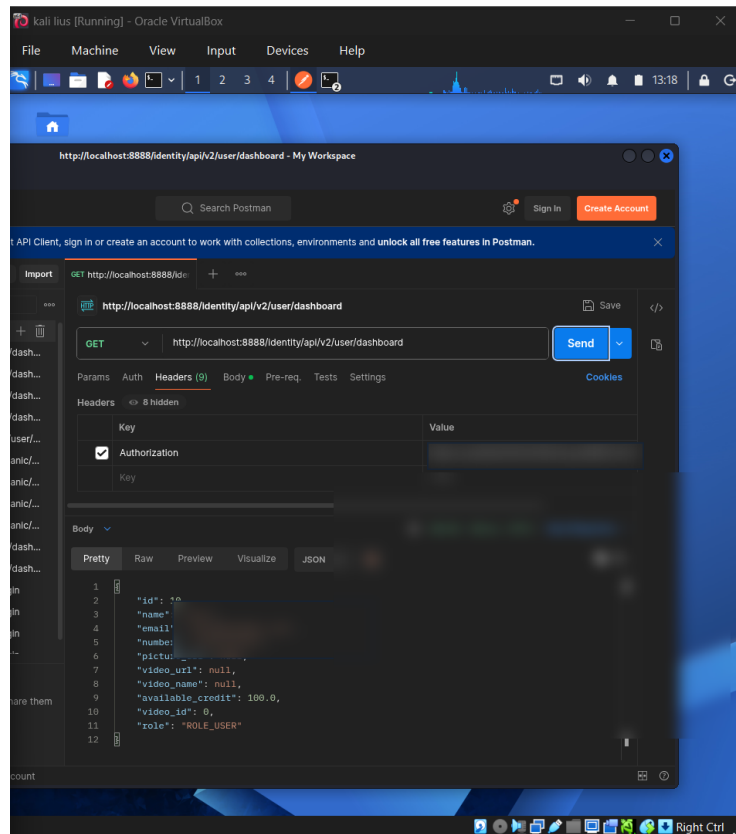


Figure 1 - Embedded screenshot evidence for: Excessive data exposure

What this evidence proves

The evidence shows response body review in Postman. Sensitive values are blurred while still showing that response fields were inspected.

Evidence handling note

The screenshot has been prepared for GitHub publication. Sensitive fields such as credentials, tokens, JWTs, cookies, personal data, host values, or other secrets are blurred or represented as redacted values where needed.

2. Assessment Context and Methodology Placement

Area	Value
Testing Phase	API Response Content Review
Tool / Component	Postman Response Viewer
Assessment Objective	Review raw API responses to determine whether the backend returns fields that are not needed by the client or could expose sensitive internal data.
Result Type	Data exposure review
OWASP / Security Mapping	API3:2023 Broken Object Property Level Authorization

Why this evidence matters

APIs often return complete database objects and rely on the frontend to hide fields. This is unsafe because attackers can directly inspect raw responses.

Command / workflow used

```
Send authenticated request
Review JSON response
Identify hidden/internal fields
Classify whether returned data is necessary for the client function
```

Sanitized output style

```
Response body fields reviewed:
{
  "id": "<REVIEWED>",
  "email": "<REDACTED>",
  "role/internal_field": "<REVIEWED>",
  "business_data": "<REDACTED>"
}
```

3. Professional Interpretation

This evidence row should be interpreted as: **Data exposure review**.

Excessive data exposure can leak emails, user IDs, internal roles, object metadata, business fields, or private details even when the frontend does not display them.

Assessor notes

The report should explain which fields were unnecessary only if clearly visible and not sensitive.

How a recruiter or reviewer should read this evidence

The value of this evidence is not only the screenshot itself. The value is that it demonstrates a structured API security testing process: controlled lab setup, targeted testing, safe interpretation of results, and clear separation between confirmed vulnerabilities and controls that rejected attack attempts.

Finding interpretation

Where the evidence shows vulnerable behaviour, the report should explain the security impact, the affected object or workflow, and the remediation without publishing sensitive raw values.

4. Risk, Impact, and Remediation Guidance

Risk perspective

Excessive data exposure can leak emails, user IDs, internal roles, object metadata, business fields, or private details even when the frontend does not display them.

Recommended remediation / hardening actions

- Return only fields required by the feature.
- Use response DTOs or serializers.
- Apply field-level authorization.
- Avoid exposing raw database models.
- Review API responses during security testing.

Validation guidance after remediation

- Repeat the same test workflow after remediation and compare the response behaviour.
- Confirm that sensitive data is no longer exposed in raw API responses.
- Confirm that unauthorized requests return secure error responses such as 401 or 403 where appropriate.
- Confirm that security controls are enforced server-side, not only in the frontend or client collection.

5. GitHub Publication and Redaction Guidance

Sensitive values to redact before public upload

- Emails.
- User IDs.
- Business data.
- Vehicle or report IDs.
- Tokens and cookies.

General API evidence redaction checklist

- Blur JWT access tokens, bearer tokens, OAuth codes, cookies, and authorization headers.
- Blur email addresses, phone numbers, user IDs, vehicle IDs, order IDs, and private object identifiers.
- Do not upload Postman environment files containing live variables or secrets.
- Do not upload raw response exports containing personal data or secret-bearing values.
- Use placeholders such as , , and .

GitHub link format for 02-api-security/README.md

`[Excessive data exposure](./reports/evidence/09-excessive-data-exposure-hidden-fields-evidence-report.pdf)`

Final classification

This PDF is suitable for a public GitHub portfolio only after the embedded screenshot has been reviewed and sensitive values are confirmed blurred or removed.